

GSG-03

Policy Templates

AUP · Password Policy · Incident Response Plan

Three ready-to-customize security policy templates for small and medium businesses. Customize the highlighted fields with your organization name, then have staff acknowledge receipt. Plain language, professionally structured.

// HOW TO USE THESE TEMPLATES

This document contains three policy templates: an Acceptable Use Policy (AUP), a Password Policy, and an Incident Response Plan. Each is designed to be adapted for your organization with minimal effort.

Step 1 — Customize:

Replace [ORGANIZATION NAME] throughout each policy with your business name. Review each section and adjust any specifics — timeframes, technical details, or procedures — to match how your business actually operates.

Step 2 — Review:

Have a trusted advisor, legal counsel, or IT vendor review the policies before distributing. While these templates reflect sound practice, they should be validated against your specific industry, jurisdiction, and risk profile.

Step 3 — Distribute and Acknowledge:

Share each policy with all employees. Use the acknowledgment section at the end of each policy to record that staff have read and understood the policy. Retain signed acknowledgments.

Step 4 — Review Annually:

Schedule an annual review of each policy. Update for new technologies, changes in your business, or lessons learned from any incidents.

POLICY 1 OF 3

Acceptable Use Policy

AUP

Organization	[ORGANIZATION NAME]
Version	1.0
Effective Date	[DATE]
Review Date	Annually
Owner	[IT Manager / Business Owner]

// PURPOSE

This Acceptable Use Policy (AUP) defines the acceptable use of information technology resources owned or managed by [ORGANIZATION NAME], including computers, mobile devices, network infrastructure, internet access, email, cloud services, and any other technology used to conduct business.

The purpose of this policy is to protect [ORGANIZATION NAME], its employees, clients, and partners from harm resulting from the inappropriate or unauthorized use of technology resources.

// SCOPE

This policy applies to all employees, contractors, consultants, temporary staff, and any other individuals who are granted access to [ORGANIZATION NAME] technology resources, regardless of whether access occurs on-site or remotely.

// ACCEPTABLE USE

Business Systems and Devices

- Technology resources are provided primarily for business purposes. Limited personal use is permitted provided it does not interfere with job duties, consume excessive resources, or violate this policy.
- Employees are responsible for the appropriate use of any device assigned to them, including when used outside the workplace.
- Employees must lock or log out of their workstation when leaving it unattended.
- Business devices must not be used by family members, friends, or others not authorized by [ORGANIZATION NAME].

Email and Communications

- Email and messaging systems are provided for business use. Employees should have no expectation of privacy when using [ORGANIZATION NAME] email or communications systems.
- Employees must not use business email to send offensive, harassing, discriminatory, or illegal content.
- Employees must exercise caution when opening attachments or clicking links — particularly from unexpected or unknown senders.
- Business email addresses must not be used to register for personal accounts or services unrelated to business activities.

Internet Use

- Internet access is provided for business purposes. Reasonable personal use during breaks is permitted.
- Employees must not visit sites or download content that is illegal, obscene, harassing, or that violates this policy.
- Downloading or installing software from the internet without prior approval from [IT Manager / Business Owner] is prohibited.
- Employees must not use business internet access to conduct personal business activities or operate a personal side business.

// PROHIBITED USE

The following activities are explicitly prohibited on [ORGANIZATION NAME] technology resources:

- Accessing, storing, transmitting, or distributing illegal content of any kind.
- Unauthorized access to systems, accounts, or data belonging to [ORGANIZATION NAME], its clients, or any other party.
- Installing unauthorized software, browser extensions, or plugins on business devices.
- Sharing credentials or allowing unauthorized individuals to use your accounts.
- Circumventing security controls including firewalls, content filters, or multi-factor authentication.
- Transmitting confidential client or business data through personal email, cloud storage, or unapproved applications.
- Mining cryptocurrency or using business resources for personal financial gain.
- Using [ORGANIZATION NAME] resources to harass, threaten, or discriminate against any individual.

// DATA HANDLING

[ORGANIZATION NAME] data — including client information, financial records, employee records, and confidential business information — must be handled in accordance with the following requirements:

- Sensitive data must be stored only on approved [ORGANIZATION NAME] systems and cloud platforms.
- Sensitive data must not be transmitted via personal email, personal cloud storage, or unapproved messaging applications.

- Physical documents containing sensitive information must be secured when not in use and shredded when no longer needed.
- Employees who handle client personal or financial information must do so in compliance with applicable privacy legislation.

// INCIDENT REPORTING

Employees must immediately report the following to [IT Manager / Business Owner]:

- Suspected phishing emails, malware infections, or other security threats.
- Lost or stolen business devices.
- Unauthorized access to any business system or account.
- Any accidental disclosure of confidential business or client data.

Reporting must occur promptly. Delays in reporting increase the risk of harm to [ORGANIZATION NAME] and its clients.

// CONSEQUENCES OF VIOLATION

Violations of this policy may result in disciplinary action up to and including termination of employment or contract, legal action, or notification to law enforcement. The severity of consequences will reflect the nature, intent, and impact of the violation.

// EMPLOYEE ACKNOWLEDGMENT – ACCEPTABLE USE POLICY

By signing below, I acknowledge that I have read, understood, and agree to comply with the [ORGANIZATION NAME] Acceptable Use Policy.

Employee Name (Print)	Signature	Date

POLICY 2 OF
3

Password Policy

Credential Security
Requirements

Organization	[ORGANIZATION NAME]
Version	1.0
Effective Date	[DATE]
Review Date	Annually
Owner	[IT Manager / Business Owner]

// PURPOSE

This Password Policy establishes minimum requirements for the creation, use, protection, and management of passwords used to access [ORGANIZATION NAME] systems, accounts, and data. Compromised credentials are the leading cause of unauthorized access to business systems. Strong password practices, combined with multi-factor authentication, dramatically reduce this risk.

// SCOPE

This policy applies to all employees, contractors, and any other individuals who are granted access to [ORGANIZATION NAME] systems, including cloud services, email, network equipment, and business applications.

// PASSWORD REQUIREMENTS

Minimum Standards — All Accounts

- Passwords must be a minimum of 12 characters in length. 16 or more characters is strongly preferred.
- Passwords must not contain the user's name, email address, username, or [ORGANIZATION NAME].
- Passwords must not be reused. Do not use a password you have previously used for any [ORGANIZATION NAME] account.
- Passwords must not be based on dictionary words, keyboard patterns (e.g. qwerty123), or easily guessable personal information such as birthdays or pet names.
- The use of passphrases — a sequence of three or more random words — is encouraged as an alternative to complex passwords.

Privileged and Administrative Accounts

- Administrative accounts must use passwords of a minimum of 16 characters.
- Privileged account passwords must be unique and must not be reused across other accounts.
- Administrative passwords must be changed immediately if there is any suspicion of compromise.

// MULTI-FACTOR AUTHENTICATION (MFA)

Multi-factor authentication is required for all business accounts that support it, including:

- Email (Microsoft 365, Google Workspace, or equivalent)
- Cloud storage and productivity platforms
- Remote access and VPN

- Financial and banking systems
- Any system containing client data or sensitive business information

Employees must not share MFA codes or approve MFA prompts they did not initiate. Unexpected MFA prompts should be refused and reported immediately to [IT Manager / Business Owner].

// PASSWORD MANAGER

[ORGANIZATION NAME] provides access to a business password manager [specify tool, e.g. Bitwarden Teams] for all employees. Use of the password manager is [required/strongly encouraged] for all business accounts. The password manager eliminates the need to memorize passwords and ensures every account has a unique, strong credential.

// PROHIBITED PRACTICES

- Do not share passwords with colleagues, managers, IT support, or any other individual under any circumstances.
- Do not write passwords on sticky notes, whiteboards, or in unprotected documents.
- Do not store passwords in browser autofill without the explicit approval of [IT Manager / Business Owner].
- Do not use the same password for any business account and any personal account.
- Do not email, text, or communicate passwords through any messaging platform.

// COMPROMISED CREDENTIALS

If you believe a password has been compromised — or if you receive an unexpected password reset notification — you must:

- Change the affected password immediately.
- Report the incident to [IT Manager / Business Owner] without delay.
- Check haveibeenpwned.com to determine if your credentials have appeared in a known data breach.
- Review any accounts that use the same or similar password and change those as well.

// EMPLOYEE ACKNOWLEDGMENT — PASSWORD POLICY

By signing below, I acknowledge that I have read, understood, and agree to comply with the [ORGANIZATION NAME] Password Policy.

Employee Name (Print)	Signature	Date

**POLICY 3 OF
3**

Incident Response Plan

 Security Event
Procedures

Organization	[ORGANIZATION NAME]
Version	1.0
Effective Date	[DATE]
Last Tested	[DATE OF LAST TABLETOP EXERCISE]
Owner	[IT Manager / Business Owner]

// PURPOSE

This Incident Response Plan (IRP) defines the procedures [ORGANIZATION NAME] will follow when a security incident is detected or suspected. A security incident is any event that may have compromised the confidentiality, integrity, or availability of [ORGANIZATION NAME] systems, data, or operations — including ransomware, data breaches, phishing attacks, unauthorized access, or system outages caused by a security event.

Having a documented, practiced plan significantly reduces the time and cost of recovery. All employees should be familiar with their role in this plan.

// INCIDENT CONTACT LIST

Print this page and post it in your server room and share it with key staff before an incident occurs.

Internal Contact	[IT Manager / Business Owner name and cell number]
IT Vendor / MSP	[Vendor name, contact name, phone, email]
Cyber Insurance	[Insurer name, policy number, claims hotline]
Legal Counsel	[Lawyer name and phone number]
CCCS (Canada)	1-833-CYBER-88 · cyber.gc.ca
CISA (US)	1-888-282-0870 · cisa.gov/report

// PHASE 1 – IDENTIFICATION

Indicators of a Potential Incident

- Unusual system behavior: slow performance, unexpected reboots, files appearing or disappearing.
- Ransomware note or encrypted files that cannot be opened.
- Unexpected account lockouts or password reset notifications you did not initiate.
- Reports from staff of suspicious emails, unexpected MFA prompts, or strange pop-ups.
- Alerts from your antivirus, EDR, or firewall.
- Discovery of unauthorized accounts, software, or changes to system configuration.

→ Client or vendor notification that they received unusual communications from your organization.

Initial Assessment

When a potential incident is identified, the employee who discovers it must immediately notify [IT Manager / Business Owner]. Do not attempt to resolve the situation independently. Do not power off affected systems unless specifically instructed to do so by your IT vendor — this may destroy forensic evidence.

// PHASE 2 – CONTAINMENT

The goal of containment is to stop the incident from spreading while preserving evidence. Actions will vary based on the type and scope of the incident.

Immediate Containment Steps:

- Isolate affected systems from the network by unplugging the network cable or disabling Wi-Fi — but do not power off unless advised.
- Revoke credentials for any accounts that may be compromised. Reset passwords and disable active sessions.
- Notify your IT vendor or MSP immediately. Engage them to lead technical containment if you do not have internal capability.
- Preserve logs and evidence: do not delete files, emails, or system logs related to the incident.
- Document everything: who discovered the incident, when, what they observed, and what actions were taken.

// PHASE 3 – NOTIFICATION

[ORGANIZATION NAME] may have legal obligations to notify affected individuals, regulators, or law enforcement depending on the nature and scope of the incident. Contact your legal counsel promptly.

- Canada — PIPEDA requires notification of a breach of security safeguards that poses a real risk of significant harm to affected individuals. Report to the Office of the Privacy Commissioner at priv.gc.ca.
- Quebec — Law 25 imposes additional breach notification requirements. Contact legal counsel familiar with Quebec privacy law.
- Healthcare — If protected health information is involved, additional obligations may apply under applicable provincial health privacy legislation.
- Payment card data — If payment card data was involved, notify your payment processor and card brands. PCI DSS breach notification requirements apply.
- Contact your cyber liability insurer at the earliest possible stage. Many policies require prompt notification to preserve coverage.

// PHASE 4 – RECOVERY

- Restore affected systems from clean backups after confirming the threat has been removed.
- Verify backup integrity before restoring. Do not restore from a backup that may itself be infected.
- Reset all credentials on affected systems and any systems that shared credentials.
- Engage your IT vendor to confirm systems are clean before returning them to production.
- Communicate clearly with staff about the incident, what steps were taken, and any changes to procedures.

// PHASE 5 – POST-INCIDENT REVIEW

Within 30 days of resolution, conduct a post-incident review with key stakeholders to answer the following:

- What happened, and what was the root cause?
- How was the incident detected — and could it have been detected sooner?

- What went well in the response? What could have been better?
- What changes to controls, procedures, or training are needed to prevent recurrence?
- Does this Incident Response Plan need to be updated based on what was learned?

Document the answers and update this plan accordingly. Brief all staff on key lessons learned within 60 days of the incident.

// ANNUAL TESTING

[ORGANIZATION NAME] will conduct a tabletop exercise at least once per year to walk through a simulated incident scenario. The tabletop exercise tests this plan without a real incident and identifies gaps before they matter. All key staff should participate.

// AI DISCLOSURE

Developed with assistance from Claude (Anthropic). Reviewed and validated by Paul Green, CISSP.